

O que realmente está exposto?

Na A01, aprendemos a não confundir correlação com causa. Agora o servidor entrega um arquivo interno: precisamos ligar a evidência ao ativo, à fraqueza e à consequência antes de priorizar a resposta.

O código 200 prova entrega; ainda não explica alcance, intenção ou impacto.



**HTTP/1.1
200 OK**

Aprender a explicar uma exposição observada

Não vamos procurar falhas: vamos analisar juntos uma evidência conhecida.

1

OBSERVAR

o servidor entregou
o quê?

2

NOMEAR

qual ativo e quais
conceitos?

3

DECIDIR

qual controle faz
sentido?

4

VALIDAR

como provar que
melhorou?

Ao final, você conseguirá escrever: evidência → ativo → hipótese de fraqueza → vulnerabilidade → consequência → controle → reteste.

Cada estudante abre o Juice Shop no próprio computador

127.0.0.1 significa esta máquina; não é um servidor fornecido pelo professor.

POWERSHELL OU TERMINAL LINUX

```
docker pull bkimminich/juice-shop
```

```
docker run --rm -d --name juice-shop-a02  
-p 127.0.0.1:3000:3000 bkimminich/juice-shop
```

ABRA

http://127.0.0.1:3000

POR QUE LOCAL?

A aplicação é vulnerável de propósito. Mantê-la em 127.0.0.1 limita o acesso à própria máquina.

Uma URL, uma requisição e limites claros

Professor e turma executam juntos; ninguém precisa descobrir uma rota.

```
ABRA NO NAVEGADOR  
http://127.0.0.1:3000/ftp/acquisitions.md
```

```
REQUISIÇÃO OBSERVADA  
GET /ftp/acquisitions.md HTTP/1.1  
Host: 127.0.0.1:3000
```

```
RESPOSTA ESPERADA  
HTTP/1.1 200 OK • text/markdown
```

ANTES DE EXPLICAR

1. O que foi observado?
2. Qual informação tem valor?
3. O que ainda é hipótese?

200 prova entrega naquela requisição — não prova causa, intenção ou alcance.

O que tem valor nesta evidência?

Comece pelo que perderia valor — não pela técnica nem pelo equipamento.

CANDIDATO	POR QUE PODE SER ATIVO?	EVIDÊNCIA NO CASO
informação de aquisição	apoia decisões e deveria permanecer restrita	conteúdo declara confidencialidade
arquivo acquisitions.md	armazena e transporta a informação	nome, caminho e tipo markdown
rota/serviço web	torna o recurso acessível	GET recebeu resposta 200
container Juice Shop	executa a aplicação do laboratório	docker ps + endereço local

Ativo não é sinônimo de servidor: informação, arquivo, serviço e plataforma sustentam funções diferentes.

Da evidência aos conceitos necessários

Primeiro modele a frase: depois peça que as duplas a critiquem e completem.

1 • ATIVO

informação do arquivo acquisitions.md

3 • FRAQUEZA — HIPÓTESE

arquivo em área servida ou autorização ausente

5 • AMEAÇA

usuário não autorizado obtém a informação

2 • OBSERVAÇÃO

GET sem login recebeu 200 + markdown

4 • VULNERABILIDADE

esta implantação permite acesso não autenticado

6 • CONSEQUÊNCIA

divulgação de planos fictícios de aquisição

Uma medida que modifica o risco

O controle entra depois que entendemos ativo, exposição e consequência.



Controles podem atuar em camadas. Detectar não substitui prevenir ou corrigir quando a exposição permanece.

CHECKPOINT 2

Qual controle você defenderia?

REMOVER

recurso não deveria ser
servido

AUTORIZAR

papel específico precisa
acessar

MONITORAR

correção imediata é inviável

Declare a premissa e a evidência de reteste.

Uma frase profissional liga os conceitos

A dupla receberá pontos de partida e deverá justificar limites e evidências.

Nesta implantação, uma requisição GET sem autenticação recebeu 200 e entregou o arquivo acquisitions.md. Isso expõe informação fictícia de aquisição a um usuário não autorizado. A condição provável ainda precisa ser confirmada na arquitetura.

A dupla deve marcar na frase:

evidência observada • ativo • vulnerabilidade concreta • ameaça • consequência • hipótese de fraqueza

Suba localmente, investigue e encerre com segurança

Cada estudante acessa seu próprio container em <http://127.0.0.1:3000>.

PREPARAÇÃO — POWERSHELL OU TERMINAL LINUX

```
docker pull bkimminich/juice-shop  
docker run --rm -d --name juice-shop-a02 -p  
127.0.0.1:3000:3000 bkimminich/juice-shop
```

ABRA <http://127.0.0.1:3000>

ENCERRE `docker stop juice-shop-a02`

ENTREGA

Inventário do Juice Shop
Evidência interpretada
Controle justificado
Reteste definido

Sem credenciais ou dados reais

Inventário orienta a prioridade

A terminologia conecta evidência, causa, consequência, ação e validação.

INVENTARIAR

OBSERVAR

EXPLICAR

TRATAR

RETESTAR

Transferência: qual consequência física mudaria sua prioridade em uma HMI?